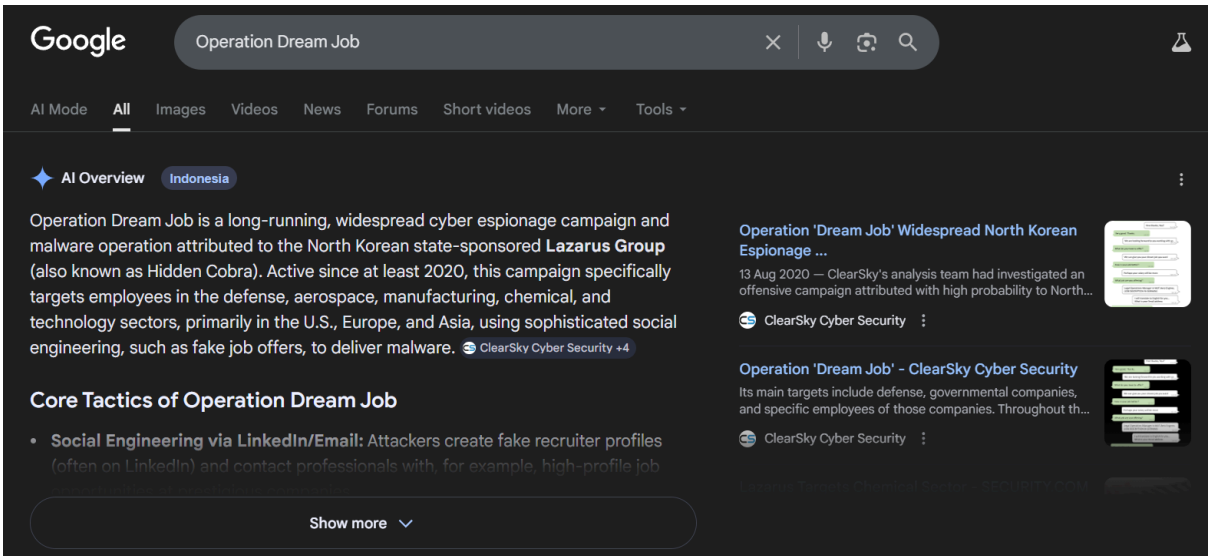
Rafael Angelo Christianto

HACK THE BOX SHERLOCK - DFIR

DREAMJOB-1

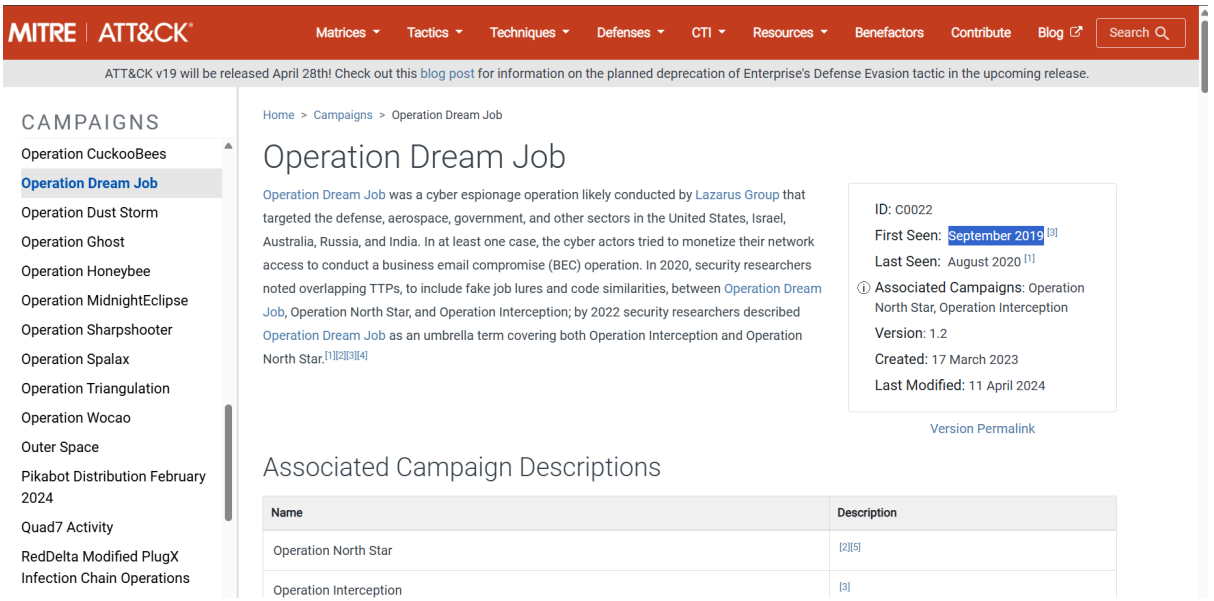
Operation Dream Job website:
https://attack.mitre.org/campaigns/C0022/

1. Who conducted Operation Dream Job?



After Googling it, we found that Operation Dream Job is a malware operation campaign attributed to the North Korean hacker group, **Lazarus Group**

2. When was this operation first observed?



Seen from the screenshot above, this Operation Dream Job was first seen in September **2019**.

3. There are 2 campaigns associated with Operation Dream Job. One is Operation North Star, what is the other?

Associated Campaign Descriptions

Name	Description
Operation North Star	[2][5]
Operation Interception	[3]

Also can be seen in the screenshot in the previous question, in the Associated Campaign Descriptions, the other campaign name is **Operation Interception**

4. During Operation Dream Job, there were the two system binaries used for proxy execution. One was Regsvr32, what was the other?

Enterprise	T1218	.010	System Binary Proxy Execution: Regsvr32	During Operation Dream Job, Lazarus Group used `regsvr32` to execute malware.[3]
		.011	System Binary Proxy Execution: Rundll32	During Operation Dream Job, Lazarus Group executed malware with `C:\\windows\system32\rundll32.exe "C:\ProgramData\ThumbNail\thumbnail.db", CtrlPanel S-6-81-3811-75432205-060098-6872 0 0 905`.[1][3][2]

Here we can see the other system binary proxy execution that was used called, **Rundll32**

5. What lateral movement technique did the adversary use?

Enterprise	T1534	Internal Spearphishing	During Operation Dream Job, Lazarus Group conducted internal spearphishing from within a compromised organization.[1]

The adversary used **Internal Spearphishing**, for the lateral movement, to gather as much information from many computers within a computer.

6. What is the technique ID for the previous answer?

Enterprise	T1534	Internal Spearphishing	During Operation Dream Job, Lazarus Group conducted internal spearphishing from within a compromised organization.[1]

The technique ID for the previous question's answer is **T1534**.

7. What Remote Access Trojan did the Lazarus Group use in Operation Dream Job?

Software

ID	Name	Description
S0694	DRATzarus	During Operation Dream Job, Lazarus Group used DRATzarus to deploy open source software and partly commodity software such as Responder, Wake-On-Lan, and ChromePass to target infected hosts.[1]
S0174	Responder	[1]
S0678	Torisma	During Operation Dream Job, Lazarus Group used Torisma to actively monitor for new drives and remote desktop connections on an infected system.[2][5]

Under the Software section, we see **DRATzarus**, where there is the word RAT in the word which is an abbreviation for Remote Access Trojan. It is used to deploy open source software such as Responder, Wake-on-Lan and ChromePass to get to infected hosts.

8. What technique did the malware use for execution?

Enterprise	T1106	Native API	During Operation Dream Job, Lazarus Group used Windows API `ObtainUserAgentString` to obtain the victim's User-Agent and used the value to connect to their C2 server.[2]

The malware uses a Windows API to get the victim's user agent and executes the malware by connecting back to the C2 server, and this technique is called **Native API**.

9. What technique did the malware use to avoid detection in a sandbox?

Enterprise	T1497	.001	Virtualization/Sandbox Evasion: System Checks	During Operation Dream Job, Lazarus Group used tools that conducted a variety of system checks to detect sandboxes or VMware services.[1]
		.003	Virtualization/Sandbox Evasion: Time Based Checks	During Operation Dream Job, Lazarus Group used tools that collected `GetTickCount` and `GetSystemTimeAsFileTime` data to detect sandbox or VMware services.[1]

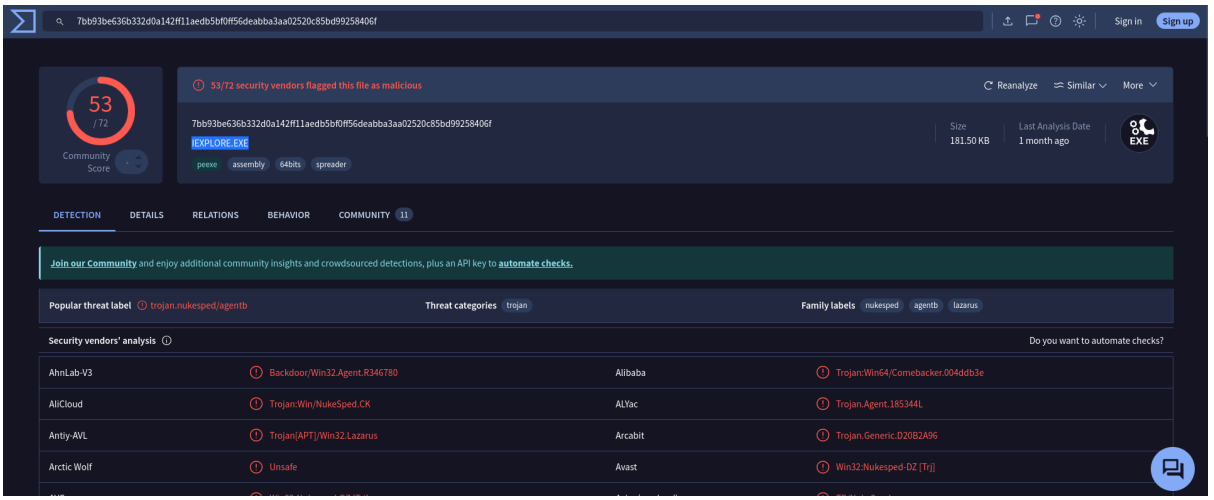
They used 2 techniques for sandbox checks, those are System Checks and Time Based Checks, where the system checks for the system whether it is a virtual machine, and the time based checks were checking system file time and tick count, but for this question since it asked for avoid detection, it is **Time Based Checks**

From this point onwards, I have downloaded the files to this Sherlock and extracted it, and seems to be there's only 1 file, IOCs.txt

```
┌──(rafael㉿raf)-[~/HTB_SHERLOCKS/DreamJob1]
└─$ ls
DreamJob1.zip  IOCs.txt
```

10. To answer the remaining questions, utilize VirusTotal and refer to the IOCs.txt file. What is the name associated with the first hash provided in the IOC file?

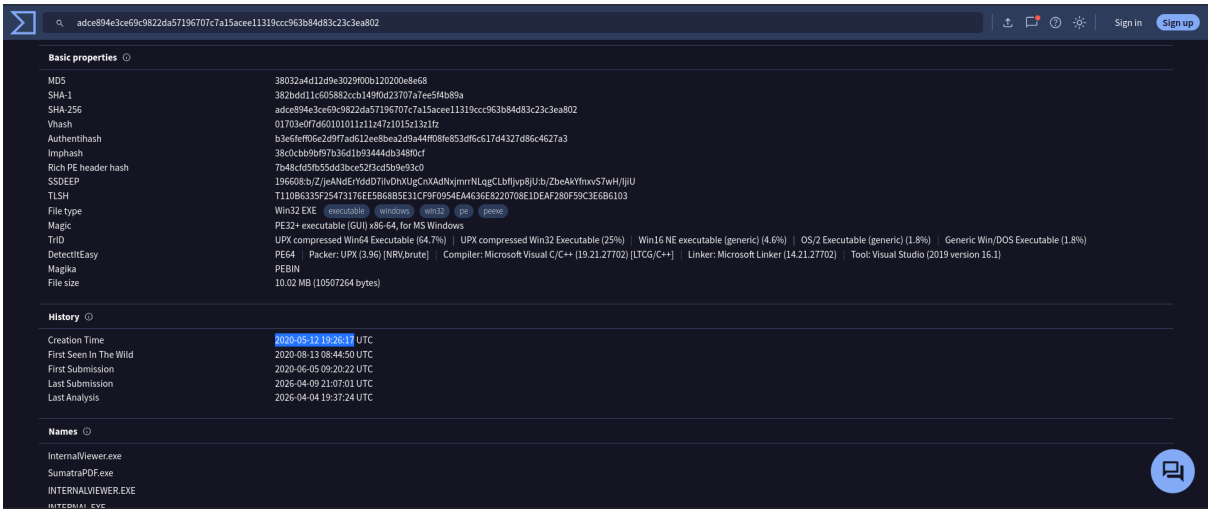
```
┌──(rafael㉿raf)-[~/HTB_SHERLOCKS/DreamJob1]
└─$ cat IOCs.txt
1. 7bb93be636b332d0a142ff11aedb5bf0ff56deabba3aa02520c85bd99258406f
2. adce894e3ce69c9822da57196707c7a15acee11319ccc963b84d83c23c3ea802
3. 0160375e19e606d06f672be6e43f70fa70093d2a30031affd2929a5c446d07c1
```



I just got the first hash in the IOCs.txt file, and put it on Virus Total. I then saw it to be **IEXPLORER.EXE** and is malicious.

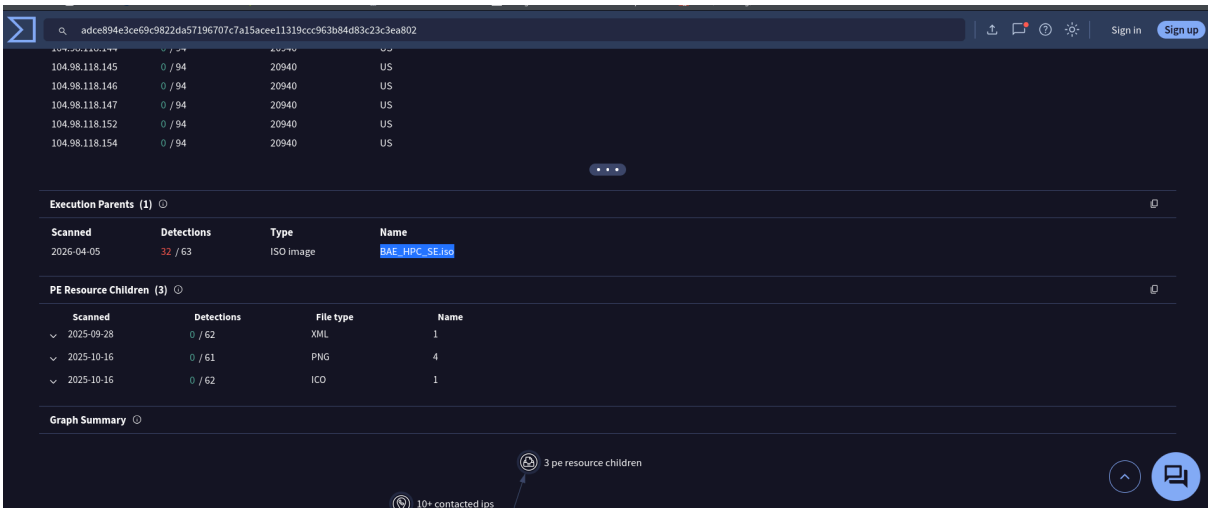
11. When was the file associated with the second hash in the IOC first created?

```
┌──(rafael㉿raf)-[~/HTB_SHERLOCKS/DreamJob1]
└─$ cat IOCs.txt
1. 7bb93be636b332d0a142ff11aedb5bf0ff56deabba3aa02520c85bd99258406f
2. adce894e3ce69c9822da57196707c7a15acee11319ccc963b84d83c23c3ea802
3. 0160375e19e606d06f672be6e43f70fa70093d2a30031affd2929a5c446d07c1
```



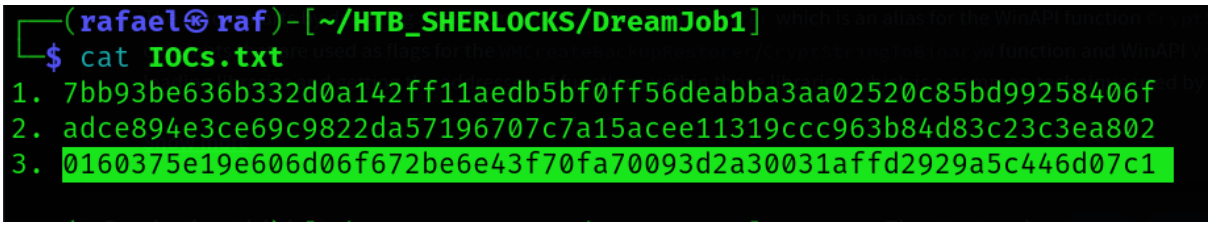
I got the 2nd hash in the IOCs.txt file and inserted the hash into Virus Total. And then I went into the details section and got **2020-05-12 19:26:17**.

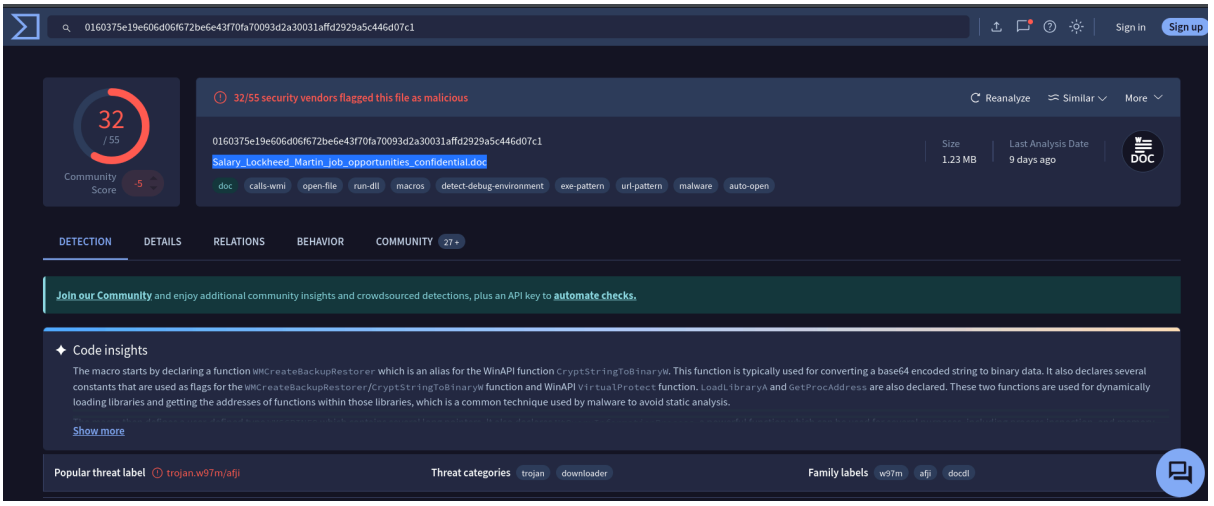
12. What is the name of the parent execution file associated with the second hash in the IOC?



Still with the second hash, its file name is SumatraPDF.exe, but then I found the section “Execution Parents”, and I found an iso file, so that has to be the answer, so the answer is **BAE_HPC_SE.iso**

13. Examine the third hash provided. What is the file name likely used in the campaign that aligns with the adversary's known tactics?





Getting the third hash now, and like explained before and in the MITRE ATT&CK website, how it did C2, lateral movement to other computers, extracting files and others. More screenshot will be given below:

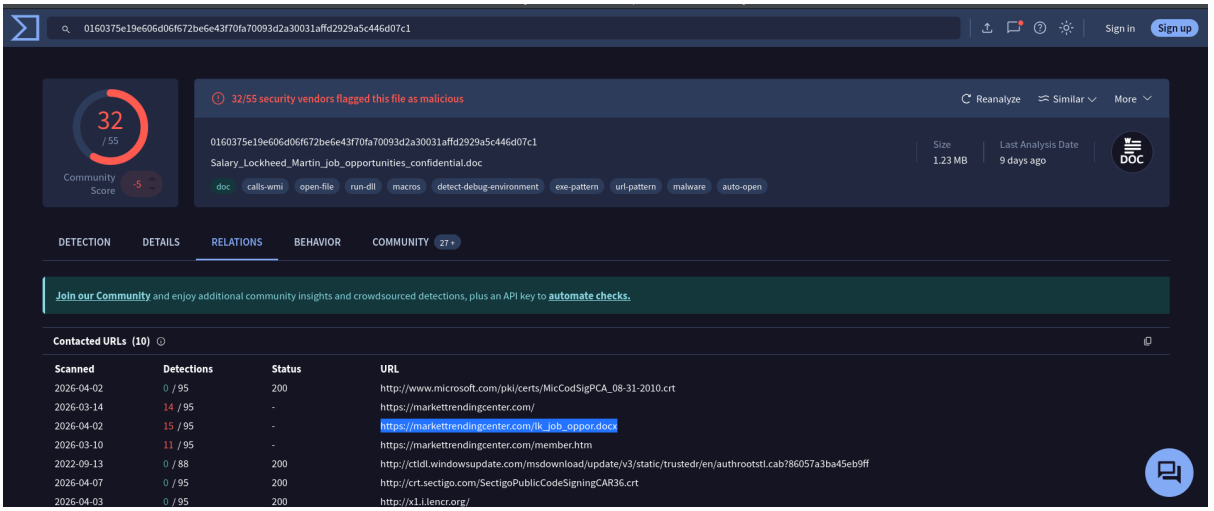
Enterprise	T1083	File and Directory Discovery	During Operation Dream Job, Lazarus Group conducted word searches within documents on a compromised host in search of security and financial matters.[1]

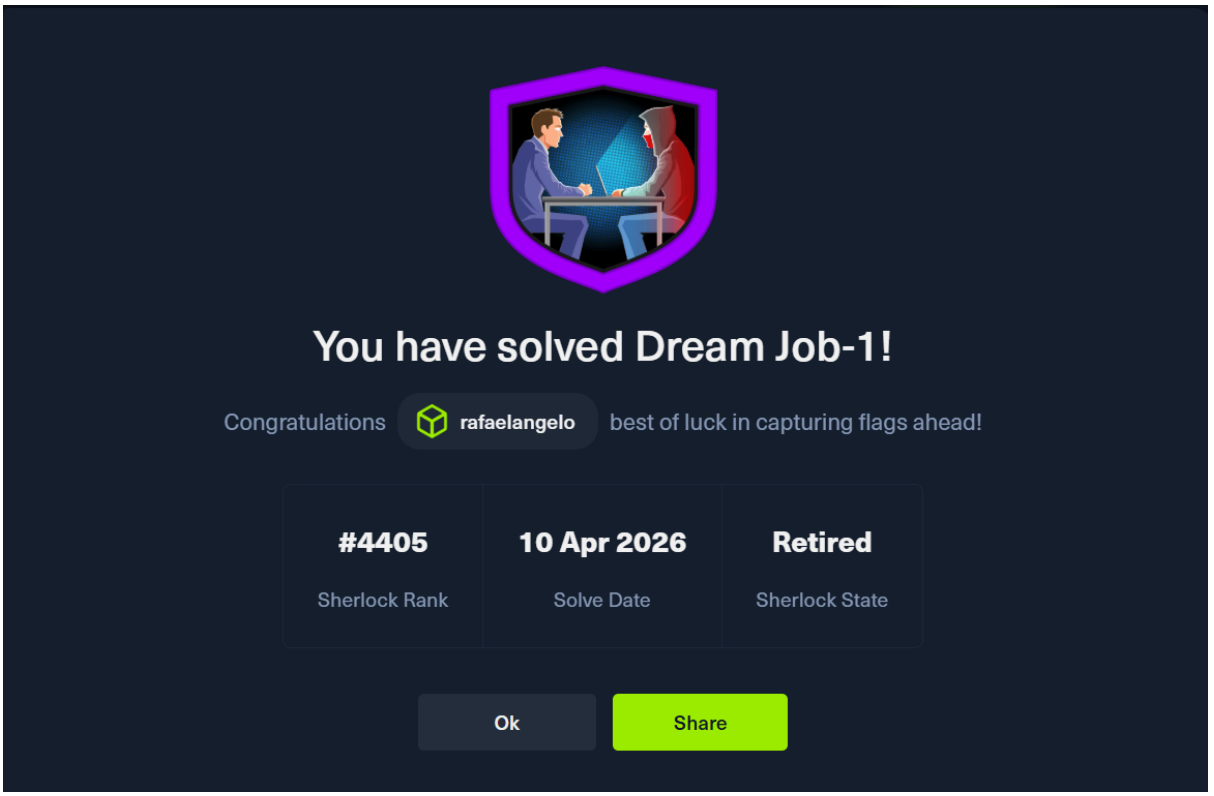
Enterprise	T1087	.002	Account Discovery: Domain Account	During Operation Dream Job, Lazarus Group queried compromised victim's active directory servers to obtain the list of employees including administrator accounts.[3]

So now after putting into Virus Total, we get the name of the file which is **Salary_Lockheed_Martin_job_opportunities_confidential.doc**.

14. Which malicious URL in the contacted URLs is used to fetch a secondary .docx file?

Rafael Angelo Christianto



Still with the 3rd hash, I got under the Relations section and there we can see Contacted URLs like mentioned in the question, and I had to find a link that would end on the file name that has a .docx extension and I found it to be

https://markettrendingcenter.com/lk_job_oppor.docx